Processo de Avaliação de Riscos e Tratamento de Riscos para Modelos de IA Generativa – Parte II

Prof. Anderson Oliveira da Silva, phD

Gestor de Segurança da Informação

Encarregado de Dados Pessoais

anderson@inf.puc-rio.br

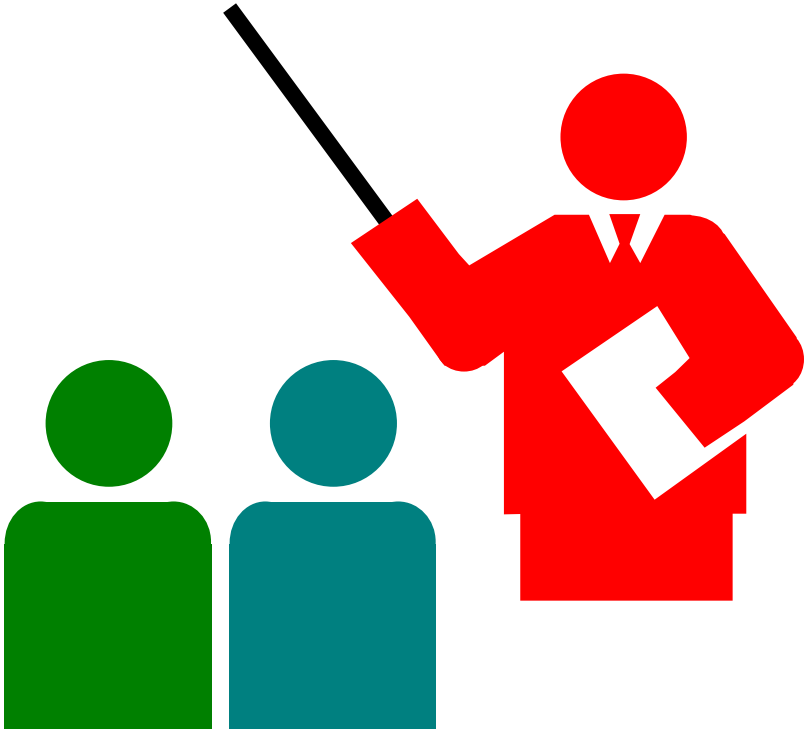
Pós-graduação em Compliance de Cibersegurança

Departamento de Informática

Coordenação Central de Educação Continuada

PUC-Rio

Processo de Avaliação de Riscos



Processo de Avaliação de Riscos – Análise de Riscos

Critério para análise de riscos: Probabilidade.

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Critério para análise de riscos: Consequência.

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Critério para análise de riscos: Matriz de Risco (Mapa de Calor).

Matriz de Risco			
	Probabilidade		
Consequência	Baixa	Média	Alta
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Processo de Avaliação de Riscos – Avaliação de Riscos

Critério para níveis de risco e tratamento recomendado:

Risco	Descrição	Tratamento
Baixo	Risco residual com impacto e probabilidade reduzidos; não exige ação adicional imediata.	Aceitar o risco, mantendo monitoramento de rotina
Médio	Risco relevante, mas gerenciável com controles adequados.	Modificar o risco com medidas de mitigação adicionais e/ou aceitar com justificativa formal.
Alto	Risco significativo aos direitos dos titulares, exigindo ação prioritária.	Modificar o risco (implementar controles robustos). Caso não seja possível reduzir, avaliar evitar o tratamento ou escalar para decisão da alta direção.
Crítico	Risco intolerável, com alto potencial de danos graves aos titulares.	Evitar o risco (interromper o tratamento) até implementação de medidas suficientes. Em situações residuais, pode-se considerar compartilhar o risco (ex.: seguro) aliado a forte mitigação, com aprovação da alta administração.

Processo de Avaliação de Riscos – Identificação de Riscos

2. Avaliação de riscos à privacidade e à proteção de dados pessoais: Modelos Generativos

- **Risco:**
  - **2.2 Falhas de transparência.**
- **Ameaças:**
  - **Falhas de transparência nos modelos generativos ocorrem quando:**
    - **Os titulares não são informados adequadamente sobre o uso de IA generativa;**
    - **Não há clareza sobre coleta, finalidade, lógica geral ou consequências do tratamento;**
    - **A organização não consegue prestar contas (rastreabilidade) sobre o uso do modelo.**

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.1	**Titulares não são informados sobre o uso de IA generativa** Probabilidade: Em sistemas de IA generativa, é comum ausência de transparência explícita (ex.: ausência de avisos claros, interfaces opacas). Há recorrência desse problema no mercado, aderente ao critério de exposição significativa. Consequência:	Alta		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.1	**Titulares não são informados sobre o uso de IA generativa** Probabilidade: Em sistemas de IA generativa, é comum ausência de transparência explícita (ex.: ausência de avisos claros, interfaces opacas). Há recorrência desse problema no mercado, aderente ao critério de exposição significativa. Consequência: Violação dos princípios da transparência e adequação (art. 6º LGPD), podendo gerar: constrangimento ao titular; perda de confiança; risco regulatório (ANPD). Não é diretamente catastrófico, mas relevante.	Alta	Média	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.1	**Titulares não são informados sobre o uso de IA generativa** Probabilidade: Em sistemas de IA generativa, é comum ausência de transparência explícita (ex.: ausência de avisos claros, interfaces opacas). Há recorrência desse problema no mercado, aderente ao critério de exposição significativa. Consequência: Violação dos princípios da transparência e adequação (art. 6º LGPD), podendo gerar: constrangimento ao titular; perda de confiança; risco regulatório (ANPD). Não é diretamente catastrófico, mas relevante.	Alta	Média	**Alto**

Matriz de Risco			
	Probabilidade		
Consequência	Baixa	Média	Alta
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.1	**Titulares não são informados sobre o uso de IA generativa** Probabilidade: Em sistemas de IA generativa, é comum ausência de transparência explícita (ex.: ausência de avisos claros, interfaces opacas). Há recorrência desse problema no mercado, aderente ao critério de exposição significativa. Consequência: Violação dos princípios da transparência e adequação (art. 6º LGPD), podendo gerar: constrangimento ao titular; perda de confiança; risco regulatório (ANPD). Não é diretamente catastrófico, mas relevante.	Alta	Média	**Alto**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.2.1	Política de governança de IA; Definição formal de finalidade; Auditoria de conformidade (LGPD).	A.2.2.1	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.2.1	Política de governança de IA; Definição formal de finalidade; Auditoria de conformidade (LGPD).	A.2.2.1	Modificar	Baixa	Baixa	Baixo

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		Pi	Ci	Ri
A.2.2.2	**Falta de clareza sobre coleta, finalidade, lógica e consequências** Probabilidade: Modelos generativos possuem natureza “black-box”, dificultando explicabilidade. A ocorrência é frequente. Consequência:	Alta		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.2	**Falta de clareza sobre coleta, finalidade, lógica e consequências** Probabilidade: Modelos generativos possuem natureza “black-box”, dificultando explicabilidade. A ocorrência é frequente. Consequência: Violação direta de múltiplos princípios LGPD: finalidade; adequação; transparência; prestação de contas. Pode gerar: decisões automatizadas opacas; discriminação por inferência; danos materiais/morais.	Alta	Alta	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.2	**Falta de clareza sobre coleta, finalidade, lógica e consequências** Probabilidade: Modelos generativos possuem natureza “black-box”, dificultando explicabilidade. A ocorrência é frequente. Consequência: Violação direta de múltiplos princípios LGPD: finalidade; adequação; transparência; prestação de contas. Pode gerar: decisões automatizadas opacas; discriminação por inferência; danos materiais/morais.	Alta	Alta	**Crítico**

Matriz de Risco			
	Probabilidade		
Consequência	Baixa	Média	Alta
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.2	**Falta de clareza sobre coleta, finalidade, lógica e consequências** Probabilidade: Modelos generativos possuem natureza “black-box”, dificultando explicabilidade. A ocorrência é frequente. Consequência: Violação direta de múltiplos princípios LGPD: finalidade; adequação; transparência; prestação de contas. Pode gerar: decisões automatizadas opacas; discriminação por inferência; danos materiais/morais.	Alta	Alta	**Crítico**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.2.2	Realização de DPIA/PIA; Curadoria de datasets; Monitoramento de bias/fairness; Re-treinamento do modelo.	A.2.2.2	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.2.2	Realização de DPIA/PIA; Curadoria de datasets; Monitoramento de bias/fairness; Re-treinamento do modelo.	A.2.2.2	Modificar	Baixa	Baixa	Baixo

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		Pi	Ci	Ri
A.2.2.3	**Falta de rastreabilidade / prestação de contas** Probabilidade: Muitas organizações ainda não possuem maturidade em MLOps e governança de IA; Porém, há evolução de ferramentas, ou seja, não é universalmente alta. Consequência:	Média		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.3	**Falta de rastreabilidade / prestação de contas** Probabilidade: Muitas organizações ainda não possuem maturidade em MLOps e governança de IA; Porém, há evolução de ferramentas, ou seja, não é universalmente alta. Consequência: Violação do princípio de responsabilização e prestação de contas (art. 6º, X LGPD); Incapacidade de auditar decisões; responder à ANPD; e investigar incidentes.	Média	Alta	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.3	**Falta de rastreabilidade / prestação de contas** Probabilidade: Muitas organizações ainda não possuem maturidade em MLOps e governança de IA; Porém, há evolução de ferramentas, ou seja, não é universalmente alta. Consequência: Violação do princípio de responsabilização e prestação de contas (art. 6º, X LGPD); Incapacidade de auditar decisões; responder à ANPD; e investigar incidentes.	Média	Alta	**Alto**

Matriz de Risco			
	Probabilidade		
Consequência	Baixa	Média	Alta
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.2 Falhas de transparência		**Pi**	**Ci**	**Ri**
A.2.2.3	**Falta de rastreabilidade / prestação de contas** Probabilidade: Muitas organizações ainda não possuem maturidade em MLOps e governança de IA; Porém, há evolução de ferramentas, ou seja, não é universalmente alta. Consequência: Violação do princípio de responsabilização e prestação de contas (art. 6º, X LGPD); Incapacidade de auditar decisões; responder à ANPD; e investigar incidentes.	Média	Alta	**Alto**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.2.3	Política de governança de IA; logging estruturado; monitoramento com SIEM; plano de resposta a incidentes.	A.2.2.3	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.2.3	Política de governança de IA; logging estruturado; monitoramento com SIEM; plano de resposta a incidentes.	A.2.2.3	Modificar	Baixa	Baixa	Baixo

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Identificação de Riscos

2. Avaliação de riscos à privacidade e à proteção de dados pessoais: Modelos Generativos

- **Risco:**
  - **2.3 Perfilamento e inferência comportamental.**
- **Ameaças:**
  - **Modelos generativos podem realizar:**
    - **Perfilamento automático com inferência de características não explicitamente fornecidas (preferências, tendências, atributos sensíveis).**
      - **Exemplos: inferência de orientação política, religião, saúde, preferências ou traços comportamentais a partir de dados aparentemente neutros.**

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.3 Perfilamento e inferência comportamental		**Pi**	**Ci**	**Ri**
A.2.3.1	**Perfilamento automático com inferência de características não fornecidas explicitamente** Probabilidade: Modelos generativos e de ML são intrinsecamente projetados para inferir padrões latentes. A inferência de atributos ocorre mesmo sem intenção explícita. Consequência:	Alta		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.3 Perfilamento e inferência comportamental		**Pi**	**Ci**	**Ri**
A.2.3.1	**Perfilamento automático com inferência de características não fornecidas explicitamente** Probabilidade: Modelos generativos e de ML são intrinsecamente projetados para inferir padrões latentes. A inferência de atributos ocorre mesmo sem intenção explícita. Consequência: Tratamento indireto de dados pessoais sensíveis sem base legal adequada. Riscos diretos: discriminação algorítmica; decisões automatizadas enviesadas; violação da autodeterminação informativa; e danos morais relevantes.	Alta	Alta	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.3 Perfilamento e inferência comportamental		**Pi**	**Ci**	**Ri**
A.2.3.1	**Perfilamento automático com inferência de características não fornecidas explicitamente** Probabilidade: Modelos generativos e de ML são intrinsecamente projetados para inferir padrões latentes. A inferência de atributos ocorre mesmo sem intenção explícita. Consequência: Tratamento indireto de dados pessoais sensíveis sem base legal adequada. Riscos diretos: discriminação algorítmica; decisões automatizadas enviesadas; violação da autodeterminação informativa; e danos morais relevantes.	Alta	Alta	**Crítico**

Matriz de Risco			
	Probabilidade		
Consequência	Baixa	Média	Alta
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.3 Perfilamento e inferência comportamental		**Pi**	**Ci**	**Ri**
A.2.3.1	**Perfilamento automático com inferência de características não fornecidas explicitamente** Probabilidade: Modelos generativos e de ML são intrinsecamente projetados para inferir padrões latentes. A inferência de atributos ocorre mesmo sem intenção explícita. Consequência: Tratamento indireto de dados pessoais sensíveis sem base legal adequada. Riscos diretos: discriminação algorítmica; decisões automatizadas enviesadas; violação da autodeterminação informativa; e danos morais relevantes.	Alta	Alta	**Crítico**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.3.1	Data minimization by design; Curadoria e validação de datasets; Controle de reuso de dados; Avaliação contínua de outputs (detecção de inferências indevidas); atualização de guardrails.	A.2.3.1	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.3.1	Data minimization by design; Curadoria e validação de datasets; Controle de reuso de dados; Avaliação contínua de outputs (detecção de inferências indevidas).	A.2.3.1	Modificar	Baixa	Média	Baixo

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Preventivos: evitar a materialização do risco

- **Governança e Compliance:**
  - **Definição formal de finalidade (limitação do propósito)**
  - **Registro de bases legais (art. 7º e 11 da LGPD)**
  - **Realização de DPIA/PIA para casos de alto risco**
  - **Política de governança de IA (papéis, responsabilidades)**
  - **Classificação de dados (pessoais, sensíveis, anonimizados)**
- **Dados:**
  - **Data minimization by design**
  - **Data inventory e data mapping**
  - **Anonimização e pseudonimização**
  - **Validação de origem dos dados**
  - **Curadoria de datasets confiáveis**
  - **Controle de reuso de dados (purpose binding)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Preventivos: evitar a materialização do risco

- **Arquitetura e Engenharia:**
  - **Privacy by design e security by design**
  - **Escolha adequada de arquitetura (LLM vs ML tradicional)**
  - **Isolamento de contexto (sandboxing de prompts e plugins)**
  - **Controle de acesso (IAM, Zero Trust)**
  - **Criptografia de dados (em repouso e em trânsito)**
- **Treinamento e Modelo:**
  - **Uso de differential privacy**
  - **Regularização para evitar overfitting/memorização**
  - **Validação de datasets contra poisoning**
  - **Treinamento com dados sintéticos (quando aplicável)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Preventivos: evitar a materialização do risco

- **Segurança de IA:**
  - **Proteção contra prompt injection (input validation)**
  - **Hardening de APIs e endpoints**
  - **Controle de supply chain (modelos, bibliotecas, pesos)**
  - **Red teaming (teste de segurança ofensiva) antes do deployment**
- **Operação e Uso:**
  - **Definição de políticas de uso aceitável**
  - **Implementação de guardrails (filtros de conteúdo)**
  - **Limitação de taxa (rate limiting)**
  - **Segregação de ambientes (dev/test/prod)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Detectivos: identificar eventos de risco ou incidentes em tempo hábil

- **Monitoramento de uso:**
  - **Logging estruturado de prompts e respostas**
  - **Monitoramento de comportamento anômalo**
  - **Detecção de uso indevido (fraude, phishing, abuso)**
  - **Monitoramento de drift do modelo**
- **Auditoria:**
  - **Auditoria de datasets (origem, conteúdo, finalidade)**
  - **Auditoria de pipelines de ML (MLOps)**
  - **Auditoria de conformidade (LGPD, políticas internas)**
  - **Revisão periódica de base legal**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Detectivos: identificar eventos de risco ou incidentes em tempo hábil

- **Segurança:**
  - **Detecção de prompt injection**
  - **Detecção de exfiltração de dados**
  - **Monitoramento de acessos (IAM)**
  - **SIEM/SOC com correlação de eventos**
- **Qualidade e Ética:**
  - **Monitoramento de bias/fairness**
  - **Avaliação contínua de outputs (toxicidade, alucinação)**
  - **Feedback humano (human-in-the-loop)**
  - **Testes adversariais contínuos**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Detectivos: identificar eventos de risco ou incidentes em tempo hábil

- **Rastreabilidade:**
  - **Data lineage (origem e uso dos dados)**
  - **Versionamento de datasets e modelos**
  - **Trilhas de auditoria (audit trails)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Corretivos/Contingência: responder a incidentes e reduzir impacto

- **Resposta a Incidentes:**
  - **Plano de resposta a incidentes de IA**
  - **Bloqueio imediato de usuários/inputs maliciosos**
  - **Revogação de acessos comprometidos**
  - **Rollback de modelo/versão**
- **Dados:**
  - **Eliminação de dados indevidos**
  - **Anonimização emergencial**
  - **Correção ou exclusão de datasets contaminados**
  - **Notificação de incidente (art. 48 LGPD)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Corretivos/Contingência: responder a incidentes e reduzir impacto

- **Modelo:**
  - **Re-treinamento com dataset corrigido**
  - **Fine-tuning corretivo**
  - **Desativação de funcionalidades de risco**
  - **Atualização de guardrails**
- **Jurídico/Compliance:**
  - **Comunicação a titulares (quando aplicável)**
  - **Revisão de base legal**
  - **Ajuste de políticas e contratos (controlador/operador)**
  - **Registro do incidente e lições aprendidas**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Corretivos/Contingência: responder a incidentes e reduzir impacto

- **Continuidade:**
  - **Ativação de plano de continuidade (BCP)**
  - **Operação degradada (fallback para sistema determinístico)**
  - **Substituição temporária do modelo**

Obrigado!

Prof. Anderson Oliveira da Silva, phD

Gestor de Segurança da Informação

Encarregado de Dados Pessoais

anderson@inf.puc-rio.br

Pós-graduação em Compliance de Cibersegurança

Departamento de Informática

Coordenação Central de Educação Continuada

PUC-Rio